

Sprint Day 10–13 Progress & Security Review Report

Prepared for project manager review — covers Settings, Error Handling, Responsive Design, Automated Testing, Bug Fixing, and a full application security review.

Report date	Sprint window	Branch	Prepared by
2026-07-20	Day 10–13	feature/mern-backend-integration	Engineering (via Claude Code)



1. Executive Summary

All 7 items on the Day 10–13 sprint checklist are complete. **Reports** was already built in a prior sprint and required no new work beyond the responsive pass. The remaining six items — **Settings, Error Pages, Responsive Design, Testing, Bug Fixing, and UI Polish** — were implemented, verified, and are ready for review.

A full security review of the backend and frontend was also completed at the user's request, focused specifically on injection vulnerabilities (SQL/NoSQL injection and related classes). **No exploitable high- or medium-confidence vulnerabilities were found.** Two candidate issues were investigated in depth and both were ruled out after verification (details in Section 8). One low-risk hardening improvement is recommended as a precaution.

Checklist Item	Status	Notes
Reports	✓ Done (prior sprint)	Page, charts, and backend routes already existed; only the responsive pass below was outstanding.
Settings	✓ Done	Profile view, password change, theme toggle, admin-only permissions viewer.
Error Pages	✓ Done	Global error boundary + access-denied screen for restricted pages.
Responsive	✓ Done	Mobile/tablet breakpoints added to the 4 pages that were missing them.
Testing	✓ Done	23 automated backend tests across 4 suites, all passing.
Bug Fixing	✓ Done	5 concrete bugs found and fixed during a manual code-review pass.
UI Polish	✓ Done	New Settings/Error screens matched to existing card, spacing, and component conventions.

2. Settings Page (New Feature)

A self-service Settings page is now available to every role, reachable from the sidebar.

- **Profile card** — displays the logged-in user's name, email, and role.
- **Change Password card** — verifies the current password server-side before accepting a new one (minimum 6 characters), with success/error feedback.

- **Appearance card** — light/dark theme toggle, using the app's existing theme system.
- **Permissions Overview card** — admin-only view of the full role/module access matrix, for transparency into who can access what.

Scope note: hospital-branding customization and in-app role/permission editing were intentionally left out of this pass — they require a data-model change and were agreed as out of scope for this sprint.

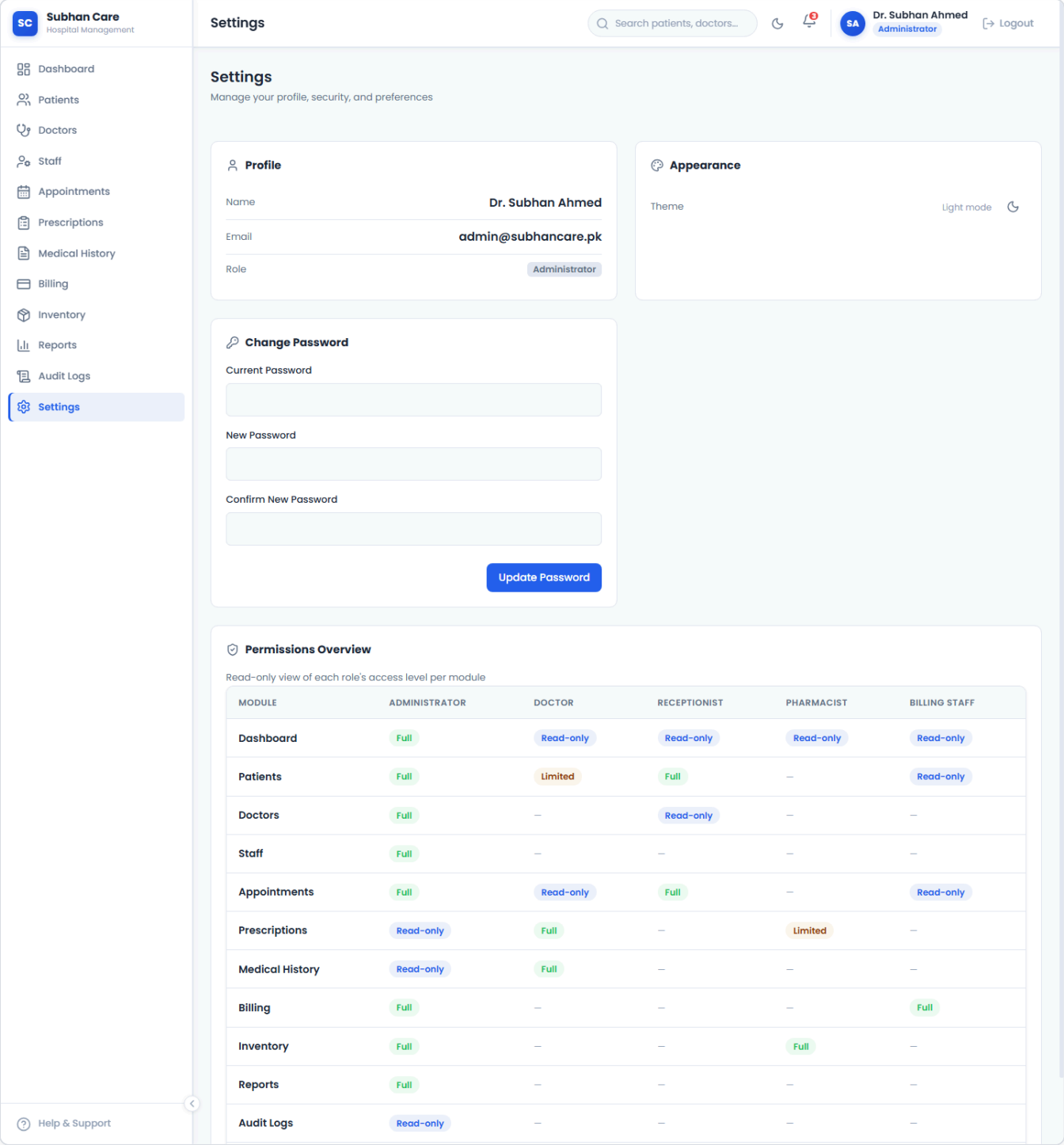


Fig. 1 — Settings page (light theme): Profile, Appearance, Change Password, and the admin-only Permissions Overview.

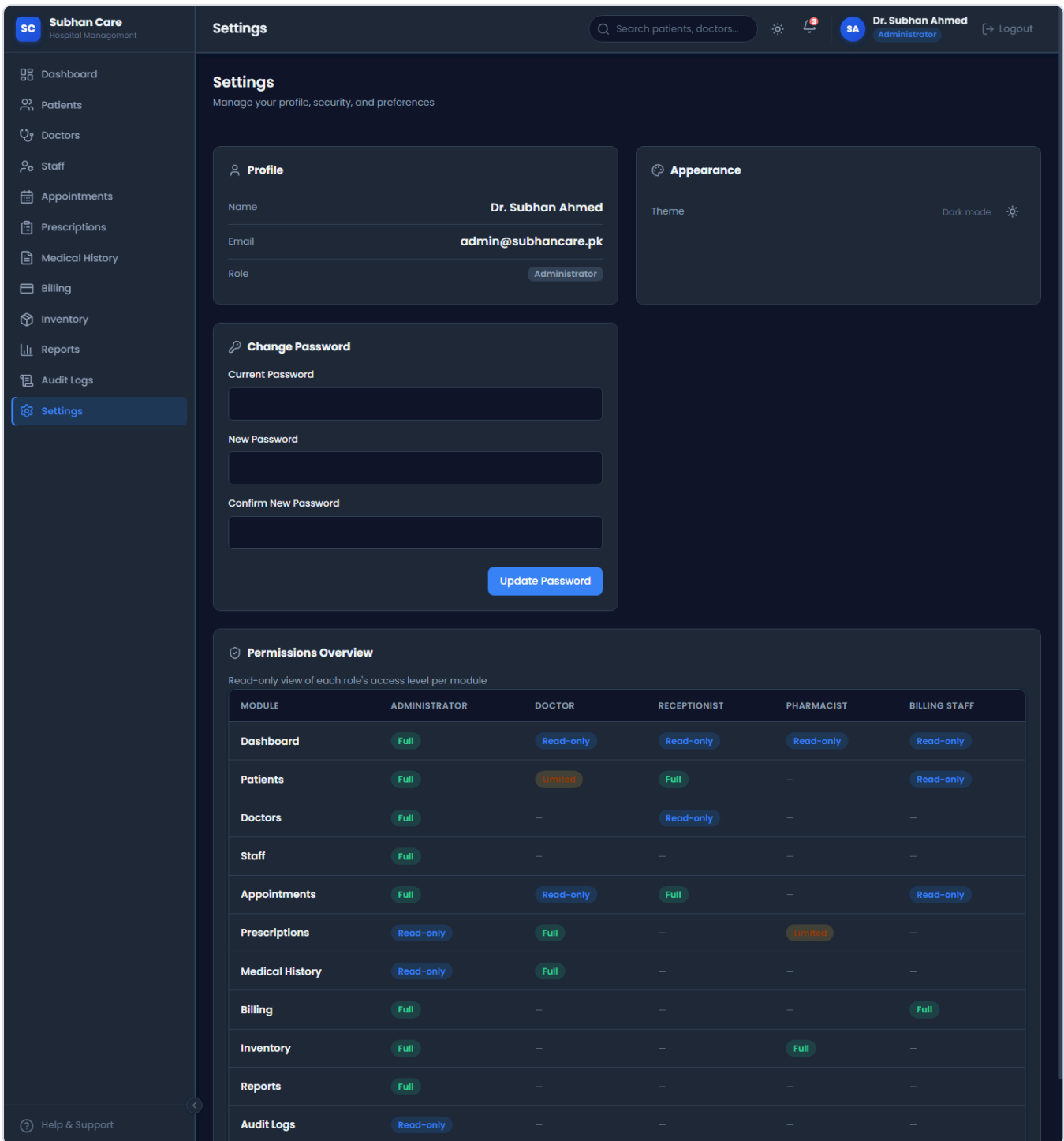


Fig. 2 — Settings page (dark theme).

3. Error Pages & Access Control

- Added a global **error boundary** so an unexpected UI crash now shows a friendly "Something went wrong" screen with a reload action, instead of a blank/broken page.
- **Fixed an access-control gap:** previously, the sidebar hid navigation links a role couldn't access, but nothing stopped a user from reaching a restricted page directly. Restricted pages now show a clear "You do not have permission to view this page" screen instead of rendering the page content.

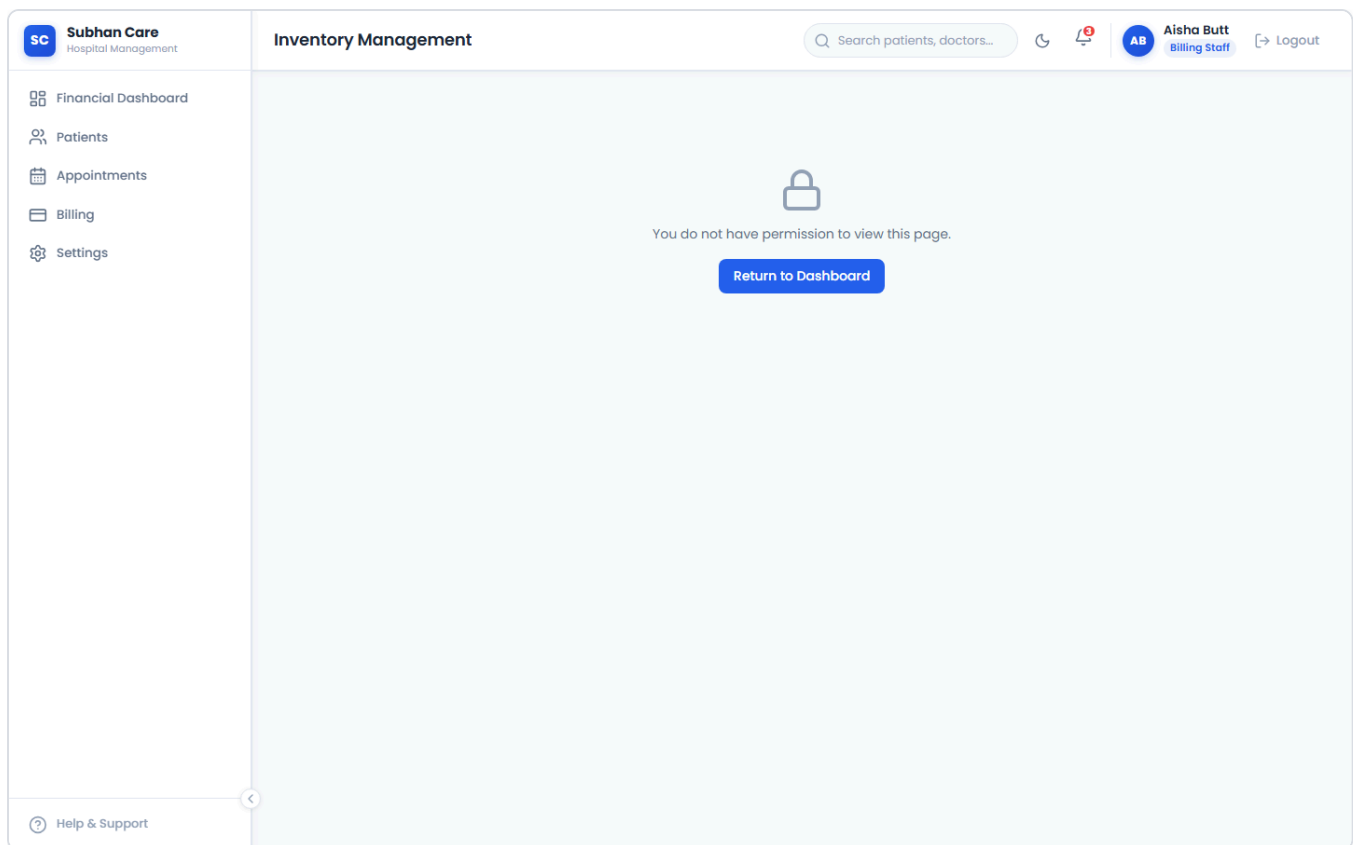


Fig. 3 — Access-denied screen, light theme (shown here: a Billing Staff account attempting to reach Inventory, a module it has no access to).

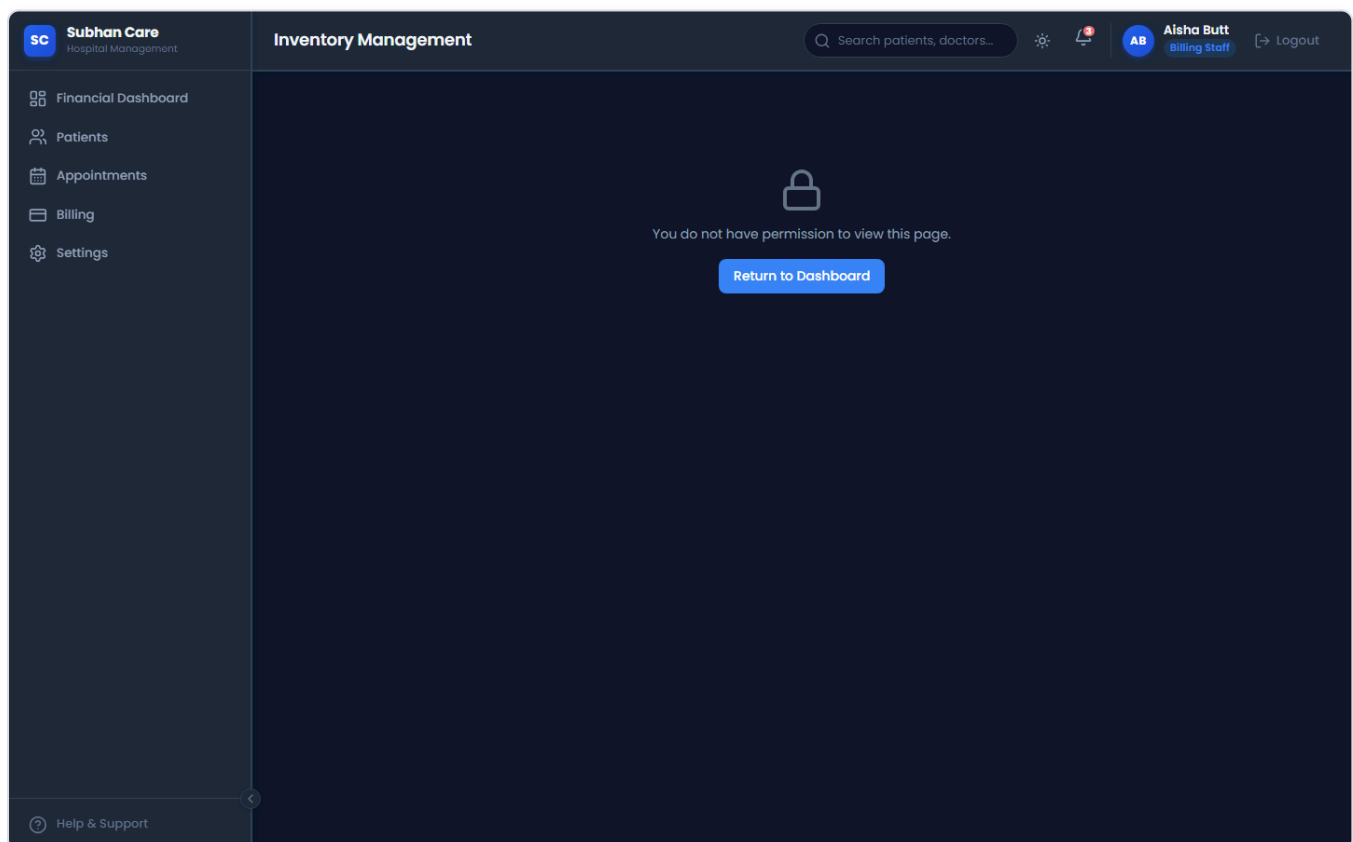


Fig. 4 — Access-denied screen, dark theme.

4. Responsive Design

Added mobile and tablet breakpoints (1024px / 768px / 480px, matching the pattern already used elsewhere in the app) to the pages that had none:

- Sidebar navigation (highest priority — present on every screen)
- Inventory, Prescriptions, and Audit Logs pages
- The new Settings and Error Boundary screens were built mobile-responsive from the start

5. Automated Testing

Added a Jest test suite for the backend — the highest-risk code, since it was newly wired to a live MongoDB database this sprint. Result:

4 test suites, 23 tests, all passing (~2.7s run time)

Suite	Coverage
Authentication & Authorization middleware	Valid/invalid/missing tokens, and all four permission-gate behaviors (module access, full-access-only actions, role-restricted actions) — tested with real signed tokens against a live Express app.
Role/Permission matrix	Confirms every role has a defined access level for every module, including the new Settings page.
Invoice math & billing status	Subtotal/total calculation, discount handling, and paid/partial/overdue/unpaid status logic.
Inventory stock status	In-stock / low-stock / out-of-stock threshold logic.

Note: testing focused on dependency-free unit and middleware tests, covering the business logic and security gates most likely to contain bugs.

```
backend - npm test

PS C:\SubhanHMS\backend> npm test

PASS tests/authMiddleware.test.js
  authenticate
    ✓ rejects requests with no token
    ✓ rejects an invalid token
    ✓ accepts a valid token and attaches req.user
  authorize
    ✓ 403s a role with no access to the module
    ✓ allows a role with read/limited/full access to the module
  requireFull
    ✓ 403s a role without full access
    ✓ allows a role with full access
  requireRole
    ✓ 403s a role not in the allowed list
    ✓ allows a role in the allowed list
PASS tests/permissions.test.js
  accessFor
    ✓ returns the configured access level for a known role/module pair
    ✓ returns null for a module the role has no access to
    ✓ returns null for an unknown role
    ✓ every role has an entry for every module referenced across the matrix
    ✓ every role can view its own settings page
PASS tests/inventoryStatus.test.js
  deriveInventoryStatus
    ✓ returns out-of-stock when quantity is zero
    ✓ returns low-stock when quantity is at or below the reorder level
    ✓ returns in-stock when quantity is above the reorder level
PASS tests/invoiceMath.test.js
  invoiceMath
    ✓ subtotalOf sums qty * rate across services
    ✓ totalOf subtracts the discount from the subtotal
    ✓ deriveInvoiceStatus returns paid when fully settled
    ✓ deriveInvoiceStatus returns overdue when unpaid past the due date
    ✓ deriveInvoiceStatus returns partial when some but not all is paid
    ✓ deriveInvoiceStatus returns unpaid when nothing is paid and not overdue

Test Suites:      4 passed, 4 total
Tests:             23 passed, 23 total
Snapshots:        0 total
Time:              2.83 s
Ran all test suites.
```

Fig. 5 — `npm test` run, backend: 4 suites / 23 tests, all passing.

6. Bug Fixing

A manual code-review pass across the five modules wired to the live backend this sprint (Appointments, Prescriptions, Medical History, Inventory, Billing) turned up and fixed:

Area	Issue & Fix
------	-------------

Status badges	A "Completed" status had no display styling and would have rendered blank; added proper label/color mapping. Affected Appointments, Inventory, Staff, and Doctors pages had a related display-prop naming bug that would have silently dropped custom status labels — fixed across all four.
Appointments actions	Advancing a status, cancelling, or rescheduling an appointment had no error feedback if the request failed — the UI would appear to silently do nothing. Added proper error toasts for all three actions.

7. UI Polish

The new Settings and Error screens were reviewed against the app's existing design conventions (card layout, spacing, typography, shared components like the toast notifications and loading skeletons) to ensure they feel native to the rest of the product rather than bolted on.

8. Security Review

At the manager/user's request, a dedicated security pass was performed across the full backend and frontend, checking for injection vulnerabilities and related risk classes, using a structured identify → independently re-verify → filter-by-confidence process (any candidate scoring below 8/10 confidence after independent re-verification is excluded from findings).

Result: no exploitable vulnerabilities confirmed

CLEAN All data access goes through parameterized query builders — no unsanitized query strings are built anywhere in the codebase.

Candidates investigated and ruled out

NoSQL query-operator injection (potential) in the appointment/prescription/invoice list filters — confidence 2/10 after re-verification. Query parameters do reach the database filter un-sanitized, but every role that can reach these endpoints already has full read access to that same data through normal use, and the one field where it could matter (a doctor's own patient list) is force-overwritten server-side regardless of what the client sends. No path to see or modify data outside a user's existing permissions was found.

Hardcoded demo account credentials in the database seed script — confidence 2/10. This is an explicitly-labeled development/demo seeding script, not production code; passwords are hashed before storage, and seed scripts of this kind are standard practice, not a code vulnerability.

Areas specifically confirmed clean

- Login token (JWT) handling — correct secret usage, no bypass paths.
- Password reset / change flows — no type-confusion or comparison bypass possible.
- API responses never expose password hashes or reset tokens to the client.
- Every backend route consistently enforces its authentication/permission checks — no route found missing checks its siblings have.
- No unsafe HTML injection points in the frontend (React's automatic escaping is intact everywhere; no unsafe HTML-injection patterns in use).

Recommended hardening (precautionary, not a confirmed vulnerability)

OPTIONAL Force query-filter values to plain strings in the appointments/prescriptions/invoices list endpoints before building the database filter. This costs nothing, closes the injection pattern permanently, and removes the need to re-litigate it in future reviews — recommended as a follow-up, not urgent.

9. Appendix — Application Screenshots

Light and dark theme views of the modules wired to live backend data this project, captured from the running application.

Appointments

This screenshot shows the 'Appointment Scheduling' interface in light theme. It features a sidebar with navigation links, a top navigation bar with a search bar and user profile, and a main content area with a table of appointments. The table columns are Patient, Doctor, Date & Time, Type, Status, and Actions. The appointments are listed with patient names, doctor names, dates, times, and their current status (Confirmed, Pending, Cancelled).

PATIENT	DOCTOR	DATE & TIME	TYPE	STATUS	ACTIONS
Ahmed Khan PI-1001	Dr. Fatima Noor	2028-07-03 09:00	Consultation	Confirmed	🗓️ ✖️ 🔄
Sara Malik PI-1002	Dr. Usman Ali	2028-07-03 09:30	Follow-up	Confirmed	🗓️ ✖️ 🔄
Hassan Raza PI-1003	Dr. Ayesha Tariq	2028-07-03 10:00	Check-up	Pending	🗓️ ✖️ 🔄
Maryam Iqbal PI-1004	Dr. Sara Riaz	2028-07-03 10:30	Consultation	Completed	🗓️ ✖️ 🔄
Bilal Chaudhry PI-1005	Dr. Fatima Noor	2028-07-04 09:00	Emergency	Pending	🗓️ ✖️ 🔄
Nida Hussain PI-1006	Dr. Usman Ali	2028-07-04 10:30	Follow-up	Cancelled	🗓️ ✖️ 🔄
Tariq Butt PI-1007	Dr. Bilal Mahmood	2028-07-05 14:00	Consultation	Confirmed	🗓️ ✖️ 🔄

This screenshot shows the 'Appointment Scheduling' interface in dark theme. The layout is identical to the light theme version, with a sidebar, top navigation bar, and a main table of appointments. The colors are inverted to match the dark theme.

PATIENT	DOCTOR	DATE & TIME	TYPE	STATUS	ACTIONS
Ahmed Khan PI-1001	Dr. Fatima Noor	2028-07-03 09:00	Consultation	Confirmed	🗓️ ✖️ 🔄
Sara Malik PI-1002	Dr. Usman Ali	2028-07-03 09:30	Follow-up	Confirmed	🗓️ ✖️ 🔄
Hassan Raza PI-1003	Dr. Ayesha Tariq	2028-07-03 10:00	Check-up	Pending	🗓️ ✖️ 🔄
Maryam Iqbal PI-1004	Dr. Sara Riaz	2028-07-03 10:30	Consultation	Completed	🗓️ ✖️ 🔄
Bilal Chaudhry PI-1005	Dr. Fatima Noor	2028-07-04 09:00	Emergency	Pending	🗓️ ✖️ 🔄
Nida Hussain PI-1006	Dr. Usman Ali	2028-07-04 10:30	Follow-up	Cancelled	🗓️ ✖️ 🔄
Tariq Butt PI-1007	Dr. Bilal Mahmood	2028-07-05 14:00	Consultation	Confirmed	🗓️ ✖️ 🔄

Light theme (left) / Dark theme (right)

Prescriptions

This screenshot shows the 'Prescription Management' interface in light theme. It includes a sidebar, top navigation bar, and a table of prescriptions. The table columns are RX ID, Patient, Doctor, Date, Diagnosis, Medications, Status, and Actions. The prescriptions are listed with patient names, doctor names, dates, diagnoses, medications, and their status (Pending, Dispensed).

RX ID	PATIENT	DOCTOR	DATE	DIAGNOSIS	MEDICATIONS	STATUS	ACTIONS
RS-1001	Hassan Raza	Dr. Fatima Noor	2028-07-03	Viral upper respiratory infection	Paracetamol 500mg Clarithromycin 500mg	Pending	📄
RS-1002	Sara Malik	Dr. Usman Ali	2028-07-03	Post-operative pain management	Ibuprofen 400mg	Dispensed	📄
RS-1003	Ahmed Khan	Dr. Fatima Noor	2028-06-28	Hypertension, Hyperlipidaemia	Amlipin 10mg Atorvastatin 10mg	Dispensed	📄

This screenshot shows the 'Prescription Management' interface in dark theme. The layout is identical to the light theme version, with a sidebar, top navigation bar, and a table of prescriptions. The colors are inverted to match the dark theme.

RX ID	PATIENT	DOCTOR	DATE	DIAGNOSIS	MEDICATIONS	STATUS	ACTIONS
RS-1001	Hassan Raza	Dr. Fatima Noor	2028-07-03	Viral upper respiratory infection	Paracetamol 500mg Clarithromycin 500mg	Pending	📄
RS-1002	Sara Malik	Dr. Usman Ali	2028-07-03	Post-operative pain management	Ibuprofen 400mg	Dispensed	📄
RS-1003	Ahmed Khan	Dr. Fatima Noor	2028-06-28	Hypertension, Hyperlipidaemia	Amlipin 10mg Atorvastatin 10mg	Dispensed	📄

Light theme (left) / Dark theme (right)

Inventory

This screenshot shows the 'Inventory Management' interface in light theme. It features a sidebar, top navigation bar, and a table of inventory items. The table columns are ID, Name, Category, Quantity, Reorder At, Unit Rate, Expiry, Status, and Actions. A warning banner at the top indicates that 3 items are low on stock or out of stock. The inventory items are listed with their names, categories, quantities, and current status (In Stock, Low Stock, Out of Stock).

ID	NAME	CATEGORY	QUANTITY	REORDER AT	UNIT RATE	EXPIRY	STATUS	ACTIONS
MS-001	Paracetamol 500mg Medipha Ltd	Analgesics	450 Tablets	100	Rs. 2.5	2027-12-31	In Stock	📄
MS-002	Amoxicillin 500mg Pharmagrip	Antibiotics	80 Capsules	100	Rs. 15	2028-09-30	Low Stock	📄
MS-003	Atorvastatin 10mg Genmed	Antihypertensives	200 Tablets	50	Rs. 8	2027-06-30	In Stock	📄
MS-004	Normal Saline 0.9% MediFlow	IV Fluids	15 Bottles	30	Rs. 60	2027-03-31	Low Stock	📄
MS-005	Insulin Glargine NovoNordisk	Antidiabetics	0 Vials	10	Rs. 450	2028-09-30	Out of Stock	📄
MS-006	Vitamin C 500mg Vitacare	Vitamins	600 Tablets	100	Rs. 3	2028-01-31	In Stock	📄

This screenshot shows the 'Inventory Management' interface in dark theme. The layout is identical to the light theme version, with a sidebar, top navigation bar, and a table of inventory items. The colors are inverted to match the dark theme.

ID	NAME	CATEGORY	QUANTITY	REORDER AT	UNIT RATE	EXPIRY	STATUS	ACTIONS
MS-001	Paracetamol 500mg Medipha Ltd	Analgesics	450 Tablets	100	Rs. 2.5	2027-12-31	In Stock	📄
MS-002	Amoxicillin 500mg Pharmagrip	Antibiotics	80 Capsules	100	Rs. 15	2028-09-30	Low Stock	📄
MS-003	Atorvastatin 10mg Genmed	Antihypertensives	200 Tablets	50	Rs. 8	2027-06-30	In Stock	📄
MS-004	Normal Saline 0.9% MediFlow	IV Fluids	15 Bottles	30	Rs. 60	2027-03-31	Low Stock	📄
MS-005	Insulin Glargine NovoNordisk	Antidiabetics	0 Vials	10	Rs. 450	2028-09-30	Out of Stock	📄
MS-006	Vitamin C 500mg Vitacare	Vitamins	600 Tablets	100	Rs. 3	2028-01-31	In Stock	📄

Light theme (left) / Dark theme (right)

Billing

Subhan Care

Dashboard

Patients

Doctors

Staff

Appointments

Prescriptions

Medical History

Billing

Inventory

Reports

Audit Logs

Settings

Help & Support

Billing & Payments

Search patients, doctors...

Dr. Subhan Ahmed

Logout

3 overdue invoices require immediate attention.

Total Collected
Rs. 4,300

Outstanding
Rs. 6,200

Overdue
3 Invoices

Invoices
4 total - 1 paid

From Appointment

Create Invoice

Search by patient, invoice ID, or service...

All Statuses

mm/dd/yyyy

mm/dd/yyyy

INVOICE	PATIENT	DATE	DUE DATE	TOTAL	PAID	OUTSTANDING	STATUS	ACTIONS
INV-001	Hassan Raza	2026-07-03	2026-07-10	Rs. 2,100	Rs. 0	Rs. 2,100	Overdue	ⓘ ⚙
INV-002	Sara Malik	2026-07-01	2026-07-08	Rs. 4,600	Rs. 2,000	Rs. 2,600	Overdue	ⓘ ⚙
INV-003	Ahmed Khan	2026-06-28	2026-07-05	Rs. 2,300	Rs. 2,300	Rs. 0	Paid	ⓘ ⚙
INV-004	Maryam Iqbal	2026-06-20	2026-06-27	Rs. 1,500	Rs. 0	Rs. 1,500	Overdue	ⓘ ⚙

Subhan Care

Dashboard

Patients

Doctors

Staff

Appointments

Prescriptions

Medical History

Billing

Inventory

Reports

Audit Logs

Settings

Help & Support

Billing & Payments

Search patients, doctors...

Dr. Subhan Ahmed

Logout

3 overdue invoices require immediate attention.

Total Collected
Rs. 4,300

Outstanding
Rs. 6,200

Overdue
3 Invoices

Invoices
4 total - 1 paid

From Appointment

Create Invoice

Search by patient, invoice ID, or service...

All Statuses

mm/dd/yyyy

mm/dd/yyyy

INVOICE	PATIENT	DATE	DUE DATE	TOTAL	PAID	OUTSTANDING	STATUS	ACTIONS
INV-001	Hassan Raza	2026-07-03	2026-07-10	Rs. 2,100	Rs. 0	Rs. 2,100	Overdue	ⓘ ⚙
INV-002	Sara Malik	2026-07-01	2026-07-08	Rs. 4,600	Rs. 2,000	Rs. 2,600	Overdue	ⓘ ⚙
INV-003	Ahmed Khan	2026-06-28	2026-07-05	Rs. 2,300	Rs. 2,300	Rs. 0	Paid	ⓘ ⚙
INV-004	Maryam Iqbal	2026-06-20	2026-06-27	Rs. 1,500	Rs. 0	Rs. 1,500	Overdue	ⓘ ⚙

Light theme (left) / Dark theme (right)

Reports

Subhan Care

Dashboard

Patients

Doctors

Staff

Appointments

Prescriptions

Medical History

Billing

Inventory

Reports

Audit Logs

Settings

Help & Support

Reports & Analytics

Search patients, doctors...

Dr. Subhan Ahmed

Logout

Reports & Analytics

Hospital-wide performance over the selected period

06/20/2026

07/20/2026

Revenue Over Time

Billed vs. collected

Inventory by Category

Current stock snapshot - 3 items low/out of stock

Prescription Trends

Issued vs. dispensed

Appointment Load

By status

Subhan Care

Dashboard

Patients

Doctors

Staff

Appointments

Prescriptions

Medical History

Billing

Inventory

Reports

Audit Logs

Settings

Help & Support

Reports & Analytics

Search patients, doctors...

Dr. Subhan Ahmed

Logout

Reports & Analytics

Hospital-wide performance over the selected period

06/20/2026

07/20/2026

Revenue Over Time

Billed vs. collected

Inventory by Category

Current stock snapshot - 3 items low/out of stock

Prescription Trends

Issued vs. dispensed

Appointment Load

By status

Light theme (left) / Dark theme (right)

Generated from the engineering session log for branch `feature/mern-backend-integration` . Automated test results and security findings reflect the state of the codebase as of the report date above.